Dquez Carr
Module 3: Lab Exercise
Vulnerability Scanning

Nessus - Installation and User Creation on KALI VM

- Cropped screenshot of KALI Linux VM 64-bit architecture

```
student@mcy670-kali:~$ sudo -s
[sudo] password for student:
root@mcy670-kali:/home/student# uname -a
Linux mcy670-kali 5.9.0-kali5-amd64 #1 SMP Debian 5.9.15-1kali1 (2020-12-18) x86_64 GNU/Linux
root@mcy670-kali:/home/student#
```

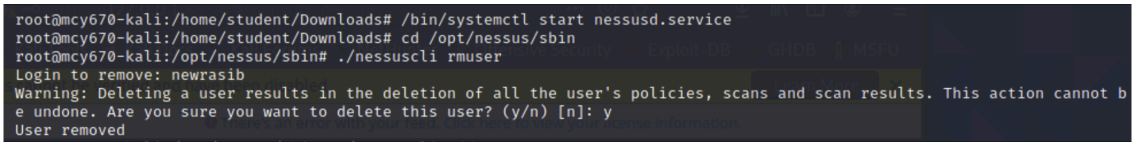
- Cropped screenshot of downloaded Nessus

```
root@mcy670-kali:/home/student# dpkg -r nessus
(Reading database ... 306757 files and directories currently installed.)
Removing nessus (10.0.0) ...
root@mcy670-kali:/home/student#
```

```
root@mcy670-kali:/home/student/Downloads# dpkg -i Nessus-10.10.1-ubuntu1604_amd64.deb
Selecting previously unselected package nessus.
(Reading database ... 306522 files and directories currently installed.)
Preparing to unpack Nessus-10.10.1-ubuntu1604_amd64.deb ...
Unpacking nessus (10.10.1) ...
Setting up nessus (10.10.1) ...
HMAC : (Module_Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
TDES : (KAT_Cipher) : Pass
AES_GCM : (KAT_Cipher) : Pass
AES_ECB_Decrypt : (KAT_Cipher) : Pass
RSA : (KAT_Signature) : RNG : (Continuous_RNG_Test) : Pass
Pass
ECDSA : (PCT_Signature) : Pass
ECDSA : (PCT_Signature) : Pass
DSA : (PCT_Signature) : Pass
TLS13_KDF_EXTRACT : (KAT_KDF) : Pass
TLS13_KDF_EXPAND : (KAT_KDF) : Pass
TLS12_PRF : (KAT_KDF) : Pass
PBKDF2 : (KAT_KDF) : Pass
SSHKDF : (KAT_KDF) : Pass
KBKDF : (KAT_KDF) : Pass
HKDF : (KAT_KDF) : Pass
SSKDF : (KAT_KDF) : Pass
X963KDF : (KAT_KDF) : Pass
X942KDF : (KAT_KDF) : Pass
HASH : (DRBG) : Pass
CTR : (DRBG) : Pass
HMAC : (DRBG) : Pass
DH : (KAT_KA) : Pass
ECDH : (KAT_KA) : Pass
RSA_Encrypt : (KAT_AsymmetricCipher) : Pass
```

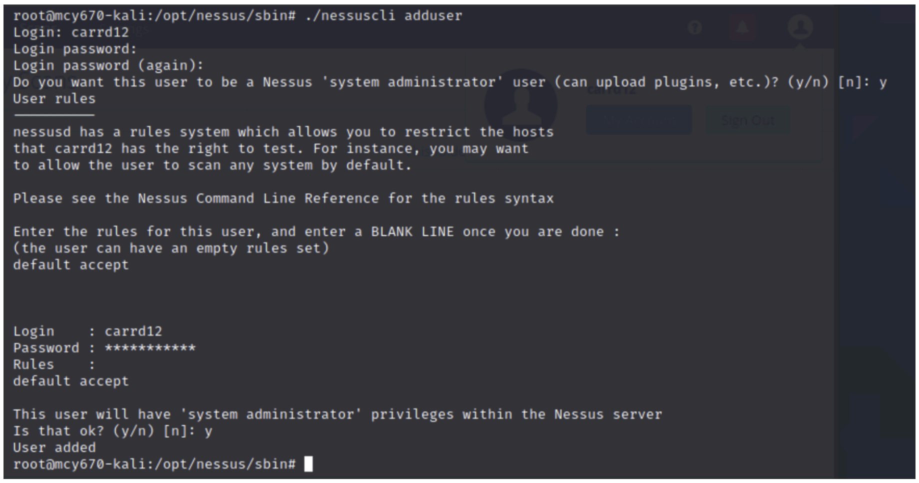
```
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
INSTALL PASSED
Unpacking Nessus Scanner Core Components...

 - You can start Nessus Scanner by typing /bin/systemctl start nessusd.service
 - Then go to https://NESSUS_HOSTNAME_OR_IP:8834/ to configure your scanner

root@mcy670-kali:/home/student/Downloads#
```

- Cropped screenshot of successfully deleting existing user



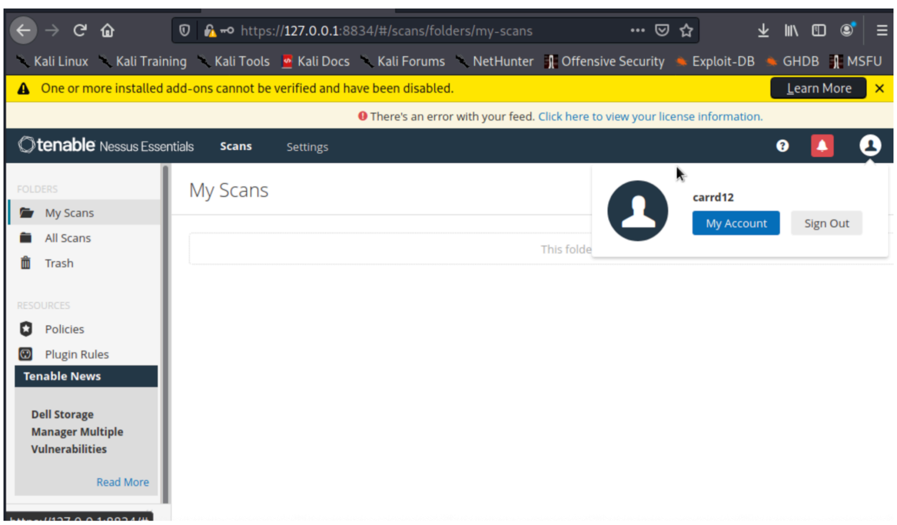
```
root@mcy670-kali:/home/student/Downloads# /bin/systemctl start nessusd.service
root@mcy670-kali:/home/student/Downloads# cd /opt/nessus/sbin
root@mcy670-kali:/opt/nessus/sbin# ./nessuscli rmuser
Login to remove: newrasib
Warning: Deleting a user results in the deletion of all the user's policies, scans and scan results. This action cannot b
e undone. Are you sure you want to delete this user? (y/n) [n]: y
User removed
```

- Cropped screenshot of successfully adding new user



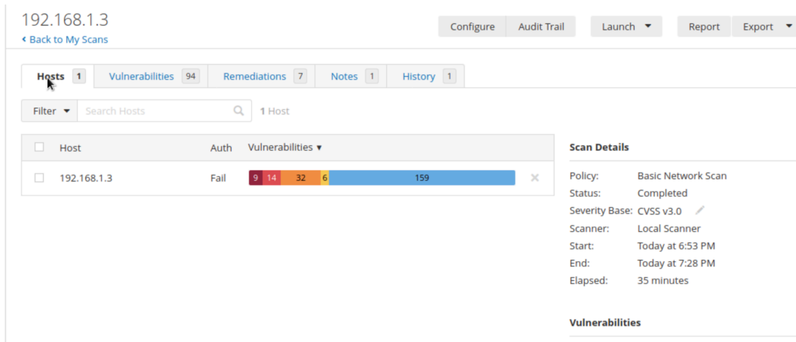
```
root@mcy670-kali:/opt/nessus/sbin# ./nessuscli adduser
Login: carrd12
Login password:
Login password (again):
Do you want this user to be a Nessus 'system administrator' user (can upload plugins, etc.)? (y/n) [n]: y
User rules
----------
nessusd has a rules system which allows you to restrict the hosts
that carrd12 has the right to test. For instance, you may want
to allow the user to scan any system by default.

Please see the Nessus Command Line Reference for the rules syntax

Enter the rules for this user, and enter a BLANK LINE once you are done :
(the user can have an empty rules set)
default accept



Login    : carrd12
Password : ***********
Rules    :
default accept

This user will have 'system administrator' privileges within the Nessus server
Is that ok? (y/n) [n]: y
User added
root@mcy670-kali:/opt/nessus/sbin#
```

- Cropped screenshot of successfully logging into Nessus web interface



Scanning for Vulnerability from KALI VM using Nessus

- META VM Scan
  - Cropped screenshot of successful completion of scan



- Cropped screenshot of vulnerabilities detected from the scan

Sev ▾	CVSS	VPR	EPSS	Family	Count
CRITICAL	10.0 *	5.9		RPC	1
CRITICAL	10.0 *	5.9		Service detection	1
CRITICAL	10.0 *			Gain a shell remotely	1
CRITICAL	9.8	9.6		Web Servers	1
CRITICAL	9.8			Backdoors	1
MIXED	...	...	...	DNS	5
MIXED	...	...	...	CGI abuses	4
CRITICAL	...	...	...	Gain a shell remotely	2
HIGH	7.5	6.7		General	1
HIGH	7.5 *	5.9		Service detection	1

- List of 5 vulnerabilities of your choice detected on your META VM.

  Remote procedure call: Remote apis that enable one machine to call functions on another are made available via RPC services. Unauthorized attackers may be able to remotely execute code, crash daemons, or enumerate services if they are misconfigured or unpatched. Mitigation strategies include limiting RPC endpoints with firewall rules and access control lists, applying vendor patches, and restricting RPC access to trusted networks.

  Service detection: This shows that the running services and versions on the virtual machine were correctly fingerprinted by Nessus. Attackers can more easily locate known exploits that correspond with those versions when services are accurately identified. Mitigation strategies include reducing the number of exposed services, running only necessary daemons, updating software, and eliminating pointless service banners and version leaks.

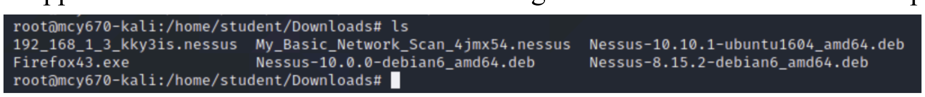
Gain a shell remotely: This discovery indicates that one or more susceptible services may let an attacker execute commands remotely on the host, resulting in a high-impact, complete control compromise. Mitigation: patch the vulnerable software right away, prevent access to the impacted ports, check logs for unusual activity, and think about isolating the host until you've fixed the issue and, if needed, reimaged it.

Web servers: Nessus identified web server-related problems, misconfigurations, out of date components, or vulnerable plugins. Information leakage, sqli/xss possibilities, file upload abuse, and remote code execution via vulnerable modules can all result from web server issues. Mitigation strategies include updating the web server and modules, hardening configurations, secure headers, deactivating directory listing, validating and sanitizing input, and, when necessary, using a web application firewall.

Backdoors: This shows signs of unauthorized remote access, such as malware or backdoor accounts that were purposefully installed. Attackers can evade standard authentication and keep ongoing control by using backdoors. Mitigation strategies include isolating the virtual machine, gathering forensic evidence, rotating credentials, cleaning, repairing, or rebuilding the system from a reliable image, doing a complete root cause analysis, and network containment.

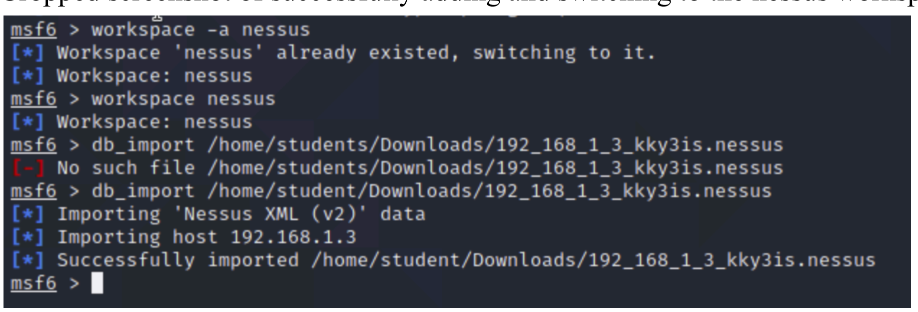
Using Metasploit to Analyze Nessus Scan Result on KALI VM

- Cropped screenshot of “ls” command showing where the scan results were exported.



```
root@mcy670-kali:/home/student/Downloads# ls
192_168_1_3_kky3is.nessus  My_Basic_Network_Scan_4jmx54.nessus  Nessus-10.10.1-ubuntu1604_amd64.deb
Firefox43.exe              Nessus-10.0.0-debian6_amd64.deb      Nessus-8.15.2-debian6_amd64.deb
root@mcy670-kali:/home/student/Downloads#
```

- Cropped screenshot of successfully adding and switching to the nessus workspace on msfconsole



```
msf6 > workspace -a nessus
[*] Workspace 'nessus' already existed, switching to it.
[*] Workspace: nessus
msf6 > workspace nessus
[*] Workspace: nessus
msf6 > db_import /home/students/Downloads/192_168_1_3_kky3is.nessus
[-] No such file /home/students/Downloads/192_168_1_3_kky3is.nessus
msf6 > db_import /home/student/Downloads/192_168_1_3_kky3is.nessus
[*] Importing 'Nessus XML (v2)' data
[*] Importing host 192.168.1.3
[*] Successfully imported /home/student/Downloads/192_168_1_3_kky3is.nessus
msf6 >
```

- Cropped screenshot of viewing imported scan results on msfconsole (hosts, vulns)

```
msf6 > hosts -c address,svcs,vulns

Hosts
=====

address       svcs  vulns
-------       ----  -----
10.2.247.5    42    268
10.2.247.8    19    275
192.168.1.3   42    218

msf6 >
```

```
2025-11-08 00:51:27 UTC  192.168.1.3  Nessus SNMP Scanner  NSS-14274
2025-11-08 00:51:27 UTC  192.168.1.3  Nessus SNMP Scanner  NSS-14274
2025-11-08 00:51:27 UTC  192.168.1.3  Nessus SNMP Scanner  NSS-14274
2025-11-08 00:51:27 UTC  192.168.1.3  Nessus SNMP Scanner  NSS-14274
2025-11-08 00:51:27 UTC  192.168.1.3  Nessus SNMP Scanner  NSS-14274
2025-11-08 00:51:27 UTC  192.168.1.3  Nessus SNMP Scanner  NSS-14274
2025-11-08 00:51:27 UTC  192.168.1.3  Nessus SNMP Scanner  NSS-14274
2025-11-08 00:51:27 UTC  192.168.1.3  Nessus SNMP Scanner  NSS-14274
2025-11-08 00:51:27 UTC  192.168.1.3  Nessus SNMP Scanner  NSS-14274
2025-11-08 00:51:27 UTC  192.168.1.3  Nessus SNMP Scanner  NSS-14274
2025-11-08 00:51:27 UTC  192.168.1.3  Nessus SNMP Scanner  NSS-14274
2025-11-08 00:51:27 UTC  192.168.1.3  Nessus SNMP Scanner  NSS-14274
2025-11-08 00:51:27 UTC  192.168.1.3  Microsoft Windows SMB NativeLanManager Remote System Information Disclosure  NSS-10785
2025-11-08 00:51:27 UTC  192.168.1.3  Samba Server Detection  NSS-25240
2025-11-08 00:51:27 UTC  192.168.1.3  Windows NetBIOS / SMB Remote Host Information Disclosure  NSS-10150
2025-11-08 00:51:27 UTC  192.168.1.3  Microsoft Windows SMB Service Detection  NSS-11011
2025-11-08 00:51:27 UTC  192.168.1.3  Microsoft Windows SMB Service Detection  NSS-11011

msf6 >
```

Using Nessus from Metasploit

- Cropped screenshot of successfully authenticating and connecting nessus from msfconsole

```
msf6 > workspace -a nessus2
[*] Workspace 'nessus2' already existed, switching to it.
[*] Workspace: nessus2
msf6 > workspace nessus2
[*] Workspace: nessus2
msf6 > load nessus2
[-] Failed to load plugin from /usr/share/metasploit-framework/plugins/nessus2: cannot load such file -- /usr/share/metas
ploit-framework/plugins/nessus2
msf6 > load nessus
[*] Nessus Bridge for Metasploit
[*] Type nessus_help for a command listing
[*] Successfully loaded plugin: Nessus
```

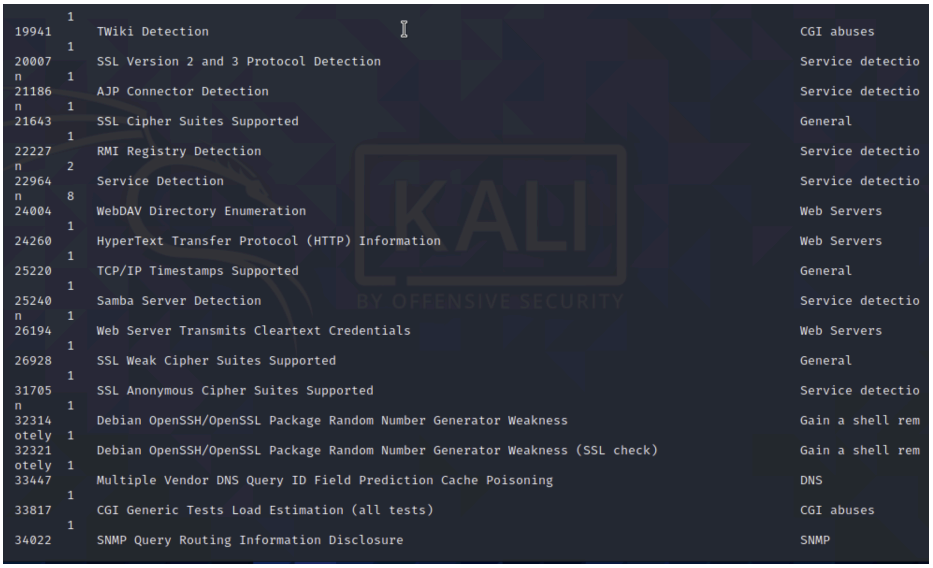
```
msf6 > nessus_connect
[*] You must do this before any other commands.
[*] Usage:
[*] nessus_connect username:password@hostname:port <ssl_verify>
[*] Example:> nessus_connect msf:msf@192.168.1.10:8834
[*] OR
[*] nessus_connect username@hostname:port ssl_verify
[*] Example:> nessus_connect msf@192.168.1.10:8834 ssl_verify
[*] OR
[*] nessus_connect hostname:port ssl_verify
[*] Example:> nessus_connect 192.168.1.10:8834 ssl_verify
[*] OR
[*] nessus_connect
[*] Example:> nessus_connect
[*] This only works after you have saved creds with nessus_save
msf6 > nessus_connect carrd12:carrd12@192.168.1.4:8834
[*] Connecting to https://192.168.1.4:8834/ as carrd12
[*] User carrd12 authenticated successfully.
msf6 >
```

- Cropped screenshots of viewing nessus scan list, hosts, and vulnerabilities.

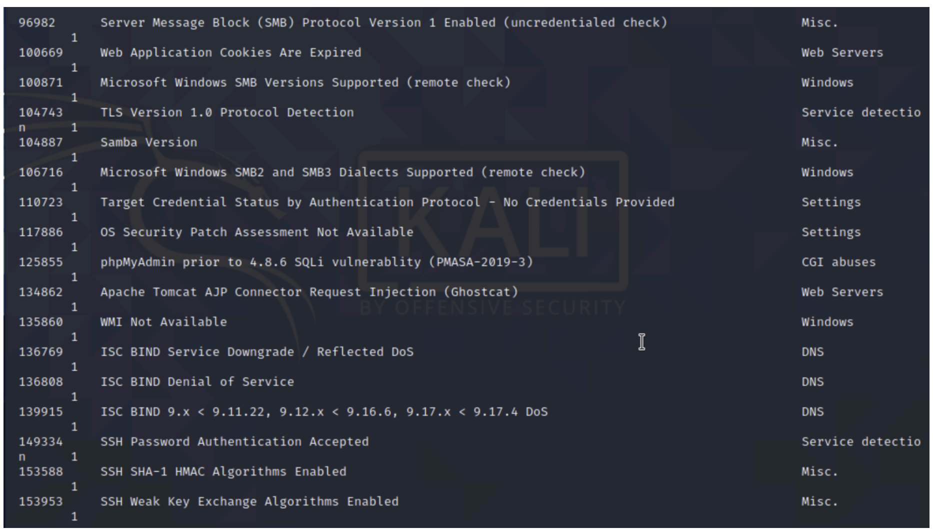
```
msf6 > nessus_scan_list
Scan ID  Name         Owner    Started  Status     Folder
-------  ----         -----    -------  ------     ------

21       192.168.1.3  carrd12           completed  19

msf6 >
```

```
msf6 > nessus_report_hosts 21

Host ID  Hostname     % of Critical Findings  % of High Findings  % of Medium Findings  % of Low Findings
-------  --------     ----------------------  ------------------  --------------------  -----------------
2        192.168.1.3  9                       14                  32                    6

msf6 >
```

```
msf6 > nessus_report_vulns 21

Plugin ID  Plugin Name                                                                  Plugin Family
       Vulnerability Count
---------  -----------                                                                  -------------
       -------------------

10028      DNS Server BIND version Directive Remote Version Detection                   DNS
       1
10092      FTP Server Detection                                                         Service detectio
n      2
10107      HTTP Server Type and Version                                                 Web Servers
       1
10114      ICMP Timestamp Request Remote Date Disclosure                                General
       1
10150      Windows NetBIOS / SMB Remote Host Information Disclosure                     Windows
       1
10203      rexecd Service Detection                                                     Service detectio
n      1
10205      rlogin Service Detection                                                     Service detectio
n      1
10223      RPC portmapper Service Detection                                             RPC
       1
10245      rsh Service Detection                                                        Service detectio
n      1
10263      SMTP Server Detection                                                        Service detectio
n      1
10267      SSH Server Type and Version Information                                      Service detectio
n      1
10281      Telnet Server Detection                                                      Service detectio
n      1
10287      Traceroute Information                                                       General
```



```
        1
19941     TWiki Detection                                                                CGI abuses
        1
20007     SSL Version 2 and 3 Protocol Detection                                         Service detectio
n       1
21186     AJP Connector Detection                                                        Service detectio
n       1
21643     SSL Cipher Suites Supported                                                    General
        1
22227     RMI Registry Detection                                                         Service detectio
n       2
22964     Service Detection                                                              Service detectio
n       8
24004     WebDAV Directory Enumeration                                                   Web Servers
        1
24260     HyperText Transfer Protocol (HTTP) Information                                 Web Servers
        1
25220     TCP/IP Timestamps Supported                                                    General
        1
25240     Samba Server Detection                                                         Service detectio
n       1
26194     Web Server Transmits Cleartext Credentials                                     Web Servers
        1
26928     SSL Weak Cipher Suites Supported                                               General
        1
31705     SSL Anonymous Cipher Suites Supported                                          Service detectio
n       1
32314     Debian OpenSSH/OpenSSL Package Random Number Generator Weakness                Gain a shell rem
otely   1
32321     Debian OpenSSH/OpenSSL Package Random Number Generator Weakness (SSL check)    Gain a shell rem
otely   1
33447     Multiple Vendor DNS Query ID Field Prediction Cache Poisoning                  DNS
        1
33817     CGI Generic Tests Load Estimation (all tests)                                  CGI abuses
        1
34022     SNMP Query Routing Information Disclosure                                      SNMP
```



```
96982     Server Message Block (SMB) Protocol Version 1 Enabled (uncredentialed check)          Misc.
        1
100669    Web Application Cookies Are Expired                                                   Web Servers
        1
100871    Microsoft Windows SMB Versions Supported (remote check)                               Windows
        1
104743    TLS Version 1.0 Protocol Detection                                                    Service detectio
n       1
104887    Samba Version                                                                         Misc.
        1
106716    Microsoft Windows SMB2 and SMB3 Dialects Supported (remote check)                     Windows
        1
110723    Target Credential Status by Authentication Protocol - No Credentials Provided         Settings
        1
117886    OS Security Patch Assessment Not Available                                            Settings
        1
125855    phpMyAdmin prior to 4.8.6 SQLi vulnerablity (PMASA-2019-3)                            CGI abuses
        1
134862    Apache Tomcat AJP Connector Request Injection (Ghostcat)                              Web Servers
        1
135860    WMI Not Available                                                                     Windows
        1
136769    ISC BIND Service Downgrade / Reflected DoS                                            DNS
        1
136808    ISC BIND Denial of Service                                                            DNS
        1
139915    ISC BIND 9.x < 9.11.22, 9.12.x < 9.16.6, 9.17.x < 9.17.4 DoS                          DNS
        1
149334    SSH Password Authentication Accepted                                                  Service detectio
n       1
153588    SSH SHA-1 HMAC Algorithms Enabled                                                     Misc.
        1
153953    SSH Weak Key Exchange Algorithms Enabled                                              Misc.
        1
```

- Cropped screenshot of nessus help command and short description how this can be useful for you. A brief command reference for managing a Nessus server from within Metasploit is provided by the nessus_help output. This reference covers everything from connecting and logging in to listing and starting scans, pausing, resuming, and stopping scans, exporting reports, importing scan results into the Metasploit database, and managing plugins, policies, and users. In actuality, this makes it easy to automate and incorporate vulnerability scans into your pentest workflow (run a Nessus scan, pull back the host/vuln list, import it to Metasploit, and start targeted exploits or verification). It also allows you to manage scans, users, and reports without switching GUIs, which improves the scalability, reproducibility, and scripting of assessment tasks.

```
msf6 > nessus_help

Command                     Help Text
-------                     ---------
Generic Commands
----------------            ----------------
nessus_connect              Connect to a Nessus server
nessus_logout               Logout from the Nessus server
nessus_login                Login into the connected Nesssus server with a different username and password
nessus_save                 Save credentials of the logged in user to nessus.yml
nessus_help                 Listing of available nessus commands
nessus_server_properties    Nessus server properties such as feed type, version, plugin set and server UUID.
nessus_server_status        Check the status of your Nessus Server
nessus_admin                Checks if user is an admin
nessus_template_list        List scan or policy templates
nessus_folder_list          List all configured folders on the Nessus server
nessus_scanner_list         List all the scanners configured on the Nessus server
Nessus Database Commands
----------------            ----------------
nessus_db_scan              Create a scan of all IP addresses in db_hosts
nessus_db_scan_workspace    Create a scan of all IP addresses in db_hosts for a given workspace
nessus_db_import            Import Nessus scan to the Metasploit connected database

Reports Commands
----------------            ----------------
nessus_report_hosts         Get list of hosts from a report
nessus_report_vulns         Get list of vulns from a report
nessus_report_host_details  Get detailed information from a report item on a host

Scan Commands
----------------            ----------------
nessus_scan_list            List of all current Nessus scans
nessus_scan_new             Create a new Nessus Scan
nessus_scan_launch          Launch a newly created scan. New scans need to be manually launched through this command
```

```
nessus_scan_pause           Pause a running Nessus scan
nessus_scan_pause_all       Pause all running Nessus scans
nessus_scan_stop            Stop a running or paused Nessus scan
nessus_scan_stop_all        Stop all running or paused Nessus scans
nessus_scan_resume          Resume a pasued Nessus scan
nessus_scan_resume_all      Resume all paused Nessus scans
nessus_scan_details         Return detailed information of a given scan
nessus_scan_export          Export a scan result in either Nessus, HTML, PDF, CSV, or DB format
nessus_scan_export_status   Check the status of an exported scan

Plugin Commands
----------------            ----------------
nessus_plugin_list          List all plugins in a particular plugin family.
nessus_family_list          List all the plugin families along with their corresponding family IDs and plugin count.
nessus_plugin_details       List details of a particular plugin

User Commands
----------------            ----------------
nessus_user_list            Show Nessus Users
nessus_user_add             Add a new Nessus User
nessus_user_del             Delete a Nessus User
nessus_user_passwd          Change Nessus Users Password

Policy Commands
----------------            ----------------
nessus_policy_list          List all polciies
nessus_policy_del           Delete a policy

msf6 >
```